加雲聯網股份有限公司

Dummy Project - OT Security Inspection and Test Protocol

版　別：1.0

制訂日期：2024 年 5 月 XX 日

修訂日期：2024 年 5 月 XX 日

制修部門：XXX

頁　數：X

核准	審查	制定

文件發行/修訂記錄

版次	發行日期	生效日期	制修內容摘要
1.0			

CONTENTS

1.0 Introduction 4
1.1 Purpose and Objectives 4
1.2 Scope of application 4
1.3 Glossary of Term and Definitions 4
1.3.1 Definitions 4
1.3.2 Abbreviations 4
1.4 Applicable Documents 5
1.4.1 Employer's Requirements 5
1.4.2 Related Documents 5
2.0 INSPECTION and TEST PLANNING 6
2.1 OVERVIEW 6
2.2 INSPECTION and TEST CATEGORIES 6
3.0 INSPECTION AND ACCEPTANCE CHECK FORMS 8
3.1 PHYSICAL INSPECTION 8
3.2 Physical security INSPECTION 9
3.3 Assets patch, firmware INSPECTION 9
3.4 Cybersecurity Function Requirements INSPECTION and TeSt 10
3.5 Data Protection INSPECTION 18
3.6 Hardware Protection INSPECTION 19
3.7 System Administration INSPECTION 19
3.8 Application Security INSPECTION 21
3.9 Network Security INSPECTION 21
3.10 Advanced Mitigation Strategies INSPECTION 22
3.11 Policies & Procedures Integration Requirements INSPECTION 23
3.12 Hardening Requirements INSPECTION 26
3.13 Vulnerability Scan 26
3.14 Inspection/Test case for SIS 27

1.0 Introduction

1.1 PURPOSE AND OBJECTIVES

The purpose of this document is to document the OT Security Inspection and Test Protocol of SuC.

1.2 SCOPE OF APPLICATION

The scope of this document is include the SCADA HMI Server in SuC.

1.3 GLOSSARY OF TERM AND DEFINITIONS

1.3.1 Definitions

Definition	**Description**
Asset Owner	Individual or organization responsible for one or more Industrial Automation and Control Systems (IACSs).
Automation Solution	Control system and any complementary hardware and software components installed and configured to operate in an IACS.
Component	One of the parts that make up a product or system.
Dependent Component	Component external to the product on which the product depends.
Integration Service Provider	Service provider that provides integration activities for an Automation Solution including design, installation, configuration, testing, commissioning, and handover.
Maintenance Service Provider	Service provider that provides support activities for an Automation Solution after handover.
Product Supplier	Manufacturer of hardware and/or software products.
Recovery Point Objective	Time value that determines the maximum tolerable period of data loss due to a disaster (e.g., data corruption).
Recovery Time Objective	The overall length of time an information system’s components or an operation system’s components can be in the recovery phase before negatively impacting the organization’s mission or mission/business/operating functions.
Service Provider	Individual or organization (internal or external organization, manufacturer, etc.) that provides a specific support service and associated supplies in accordance with an agreement with the asset owner.

1.3.2 Abbreviations

Abbreviation	**Clarification**
SAT	Site Acceptance Test
SCS	Substation Control System
SIT	Site Integration Test

1.4 APPLICABLE DOCUMENTS

1.4.1 Employer’s Requirements

No	Employer’s DOC No	DOC Title
1		
2		
3		

1.4.2 Related Documents

No	Project’s DOC No	Employer’s DOC No	DOC Title
1	DUMMY202400##	BOSS202400##	Dummy - Preliminary network diagram
2	DUMMY202400##	BOSS202400##	Dummy – Data flow diagram
3	DUMMY202400##	BOSS202400##	Dummy Project - Inventory Asset List
4	DUMMY202400##	BOSS202400##	Dummy Project - ILRA-DTRA
5	DUMMY202400##	BOSS202400##	Dummy Project - Threat and Risk Assessment Report

2.0 INSPECTION and TEST PLANNING

2.1 OVERVIEW

Inspection and test protocol, which is required in order to verify the Requirements for Security Controls, that the requirements of the cybersecurity countermeasure as prescribed in Threat and Risk Assessment Report, have been fulfilled for each autonomous system configuration prior to delivery and prior to system handover.
Verification of compliance with these requirements is primarily achieved through standard check routines, which are defined and documented by the check forms appended in this document.

2.2 INSPECTION AND TEST CATEGORIES

The following functionality will be tested for Substation Power SCADA system (SCADA HMI Server) :

- Physical Inspection /verification of physical cyber assets
- Verification of Physical security
- Verification of Assets patch, firmware etc version
- Verification of Cybersecurity Function Requirements Specification
- Verification of Data Protection Countermeasures
- Verification of Hardware Protection Countermeasures
- Verification of System Administration Countermeasures
- Verification of Application Security Countermeasures
- Verification of Network Security Countermeasures
- Verification of Advanced Mitigation Strategies
- Verification of Policies & Procedures Integration Requirements
- Verification of Hardening Requirements
- Verification of Vulnerability Management (Vulnerability Scan)

Activity	Test/Inspection	Conduct Phase		
		FAT	SAT	SIT
Physical Inspection	Inspection	V	V	V
Physical security	Inspection	V	V	V
Assets patch, firmware etc version	Inspection	V	V	
Cybersecurity Function Requirements Specification	Test/Inspection	V		
Data Protection Countermeasures	Inspection/Test		V	

Hardware Protection Countermeasures	Inspection		V	
System Administration Countermeasures	Inspection/Test		V	
Application Security Countermeasures	Inspection/Test		V	
Network Security Countermeasures	Inspection/Test		V	V
Advanced Mitigation Strategies	Inspection/Test		V	
Policies & Procedures Integration Requirements	Inspection			V
Hardening Requirements	Inspection	V	V	V
Vulnerability Management (Vulnerability Scan)	Test	V		V

Asset Name	Model	Remark
SCADA HMI Server	XXXXX	

3.0 INSPECTION AND ACCEPTANCE CHECK FORMS

3.1 PHYSICAL INSPECTION

Item	Description & Pass Criteria	Inspection/Test Steps	Results (P,N,N/A)	Remarks
1	All equipment is mounted in the specified cabinet, in accordance with approved Cabinet Arrangement Drawings (Doc. No. _____): Cabinet Name:	Check the system layout according to the Cabinet Arrangement drawings.		
2	All individual components are visually sound and fault-free (applicable for all Assets).	Check all components for any signs of defects.		
3	All individual components are correctly and firmly seated or mounted.	Check all components are installed and mounting securely.		
4	All equipment has been labeled correctly according to the project specification (applicable for all assets).	Check the labeling are as per the Cabinet Arrangement drawings.		
5				

3.2 PHYSICAL SECURITY INSPECTION

Item	Description & Pass Criteria	Inspection/Test Steps	Results (P,N,N/A)	Remarks
1	All equipment is mounted in specified cabinet and, and each cabinet having unique physical key. Cabinet Name: _____	Check that the cabinet door can be locked/unlocked with the same door key and with a padlocking facility for breaker compartments only.		
2	The physical cabinet located in a room with a physical door access system or locks. Note: In FAT, the cabinet lock will be provided to check, and the other requirements will be provided in SAT stage to check.			
3	CCTV for monitoring for cabinets is available.			
4	Security Alarms trigger for any unauthorized access to control room, tempering or other security breaches.			
5	Adequate light available around the assets, active fire suppression system installed, monitoring of temperature, humidity, dust installed.			

3.3 ASSETS PATCH, FIRMWARE INSPECTION

Item	Description & Pass Criteria	Inspection/Test Steps	Results (P,N,N/A)	Remarks
1	Using the OEM tool for each asset, note down the BIOS version if any, firmware version and latest patch date in the below table and verify that the latest versions are installed	Enter BIOS Configuration		
2	All individual components are configured and functional. Verify hardware configuration (memory, processor, etc.) as per Windows Host Server, Embedded Device, Network Device.	Noted. Verification of hardware configuration through drawing Referring to Dummy Project - Inventory Asset List and Dummy		

		Project - Simple Network Diagram 1. Run …. 2. Go to …. 3. Check the model/ serial number information		
3	Correct TCP/IP addresses are configured.	TCP/ IP address as per IP-list		
4	Service Protocols using			
5				

3.4 CYBERSECURITY FUNCTION REQUIREMENTS INSPECTION AND TEST

Item	Description & Pass Criteria	Inspection/Test Steps	Results (P,N,N/A)	Remarks
1	SR 1.01 - Human user identification and authentication <Description> The control system shall provide the capability to identify and authenticate all human users. <Passing Criteria> - The component implements an identification and authentication mechanism of human users on each accessible interface, or - The component is capable to integrate into a system-level authentication	1. Power on the server 2. Show the logon page on the screen of the server, login in		
1-1	SR 1.01 RE(1) The control system shall provide the capability to uniquely identify and authenticate all human users.	TBD		
2	SR 1.02 -Software process and device identification and authentication <Description> The control system shall provide the capability to identify and authenticate all software processes and devices. This capability shall enforce such identification and authentication on all interfaces which provide access to the control system to support least privilege in	N/A Function was not provided by Windows Host Server.		

	accordance with applicable security policies and procedures. <Passing Criteria> - The component identifies itself and authenticates to any other component - Authentication mechanism is capable to prevent attacks like man-in-the-middle or message spoofing			
3	SR 1.03 - Account management <Description> The control system shall provide the capability to support the management of all accounts by authorized users, including adding, activating, modifying, disabling and removing accounts. <Passing Criteria> - Capability to integrate into a higher-level account management system, or - Account management capability (only by authorized users, including adding, activating, modifying, disabling and removing accounts) - The essential function of the component is not affected by an availability problem of the higher -level system	1. Launch the “Control Panel” tool 2. Click “User Accounts” icon 3. Select “User Accounts” menu item to show accounts and management 4. Select “Manage Accounts” menu item to manage.		
4	SR 1.04 - Identifier management <Description> The control system shall provide the capability to support the management of identifiers by user, group, role or control system interface. <Passing Criteria> - Capability to integrate into a system that supports management of identifiers - Provide the capability to support the management of identifiers by user, group, role or control system interface	1. Launch the “Control Panel” tool 2. Click the “User Accounts” icon 3. Select the “Give other users access to this computer” menu item to show the User Accounts UI 4. Select the “Advanced” folder and click the “Advanced” menu icon 5. A “lusrmgr [Local Users and Groups (Local)] “Windows UI will appear and could be operated.		
5	SR 1.05 - Authenticator management <Description>	1. Launch the “Control Panel” tool		

	The control system shall provide the capability to: a) initialize authenticator content; b) change all default authenticators upon control system installation; c) change/refresh all authenticators; and d) protect all authenticators from unauthorized disclosure and modification when stored andtransmitted. <Passing Criteria> - Support of (initial) authenticator content - Enforced change of default authenticators after installation, or recognition of unchanged default authenticator (combined with warning message) - Periodic change of authenticators - Capability to identify and authenticate all users (human, software processes and devices) engaged in wireless communication	2. Click “User Accounts” icon 3. Select “User Accounts” menu item to show accounts and management 4. Select “Manage Accounts” menu item to manage. 5. Click “Reset Password” menu icon to manage the password		
5-1	SR 1.05 - Wireless access management <Description> The control system shall provide the capability to identify and authenticate all users (humans, software processes or devices) engaged in wireless communication. <Passing Criteria> To include; 1) data exchange to/from wireless instrumentation, 2) data exchange through a secure wireless link, 3) use of cryptographic mechanisms, if applicable 4) unique, Automation Solution-specific identifiers used for wireless networks are descriptive, but do not allow an external listener to identify the physical wireless network, its location, or owner of the wireless network.	TBD		

6	SR 1.07 - Strength of password-based authentication <Description> For control systems utilizing password-based authentication, the control system shall provide the capability to enforce configurable password strength based on minimum length and variety of character types. <Passing Criteria> - Enforce configurable password strength based on minimum length and variety of character types - Configurable password strength according to internationally recognized and proven passwor d guidelines - System providing strong and configurable external authentication (by integration into a system)	1. Launch the “Control Panel” tool 2. Click “User Accounts” icon 3. Select “User Accounts” menu item to show accounts and management 4. Select “Manage Accounts” menu item to manage. 5. Click “Reset Password” menu icon to manage the password		
7	SR 1.11 - Unsuccessful login attempts <Description> The control system shall provide the capability to enforce a limit of a configurable number of consecutive invalid access attempts by any user (human, software process or device) during a configurable time period. The control system shall provide the capability to deny access for a specified period of time or until unlocked by an administrator when this limit has been exceeded. <Passing Criteria> - Capability to enforce, for each user type (human, software, device), a configurable limit of consecutive invalid access attempts performed in a configurable time period - Capability to deny access for a specified period of time or until unlocked, when limit reached	1. Goto “Windows Administrative Tools”, Select “Local Security Policy” menu item 2. Expand the the “Account Policies” menu folder, click “Account Lockout Policy”		
8	SR 2.01 - Authorization enforcement <Description> On all interfaces, the control system shall provide the capability to enforce authorizations	1. Goto “Windows Administrative Tools”, Select “Local Security Policy” menu item		

	assigned to all human users for controlling use of the control system to support segregation of duties, role-based policies for use control and least privilege. <Passing Criteria> - Authorization mechanism is enforced on all interfaces which can accessed by human users based on their esponsibilities, as dictated by the least privilege principle - Least privilege can be applied for the authorization enforcement mechanism - Role-based use control	2. Expand the “Local Policies” menu folder, click “User Rights Assignment” for access right management		
8-1	SR 2.02 - Wireless use control <Description> The control system shall provide the capability to authorize, monitor and enforce usage restrictions for wireless connectivity to the control system according to commonly accepted security industry practices. <Passing Criteria> To include : 1) security mechanisms that prevent an intruder from gaining access to the Automation Solution using the wireless system, 2) security mechanisms that restrict access within the Automation Solution by workers with handheld wireless devices, 3) where required, security mechanisms that provide protection for remote management of wireless systems.	TBD		
9	SR 2.05 - Session lock <Description> The control system shall provide the capability to prevent further access by initiating a session lock after a configurable time period of inactivity or by manual initiation. The session lock shall remain in effect until the human user who owns the session or another authorized human user re-establishes access using appropriate identification and authentication procedures.	N/A No Web services was provided by the device.		

	<Passing Criteria> - For HMI (local or via network): - Session Lock after configurable time period of inactivity - Option to explicitly disable Session Lock (e.g. in control room scenarios) - Manual session lock - Access to session only possible using authentication procedures - Comply with session locks requested by the underlying infrastructure (operating system, control system)			
10	SR 2.06 – Remote Session termination <Description> The control system shall provide the capability to terminate a remote session either automatically after a configurable time period of inactivity or manually by the user who initiated the session. <Passing Criteria> - Remote session terminated by user who initiated session (minimum requirement) - Remote session manually terminated by a local authority/user - Remote session terminated after configurable inactive period of time	N/A No Web services was provided by the device.		
11	SR 2.08 - Auditable EVENTs <Description> The control system shall provide the capability to generate audit records relevant to security for the following categories: access control, request errors, operating system events, control system events, backup and restore events, configuration changes, potential reconnaissance activity and audit log events. Individual audit records shall include the timestamp, source (originating device, software process or human user account), category, type, event ID and event result. <Passing Criteria>	1. Goto “Event Viewer” menu UI 2. Expand the “Windows Logs” 3. Check the logs of Application, Security, System,…		

	- Audit records for following security relevant cases are generated: access control, request errors, control system events, backup and r estore events, configuration changes, audit log events - Audit records include at least the following information: timestamp, source, category, type, event ID, event result			
11-1	SR 2.11 – Timestamps <Description> The control system shall provide timestamps for use in audit record generation. <Passing Criteria> Timestamps (including date and time) of audit records should be generated using internal system clocks. If system-wide time synchronization is not present (which is typical in many installations), known offsets would be needed to support analysis of a sequence of events. In addition, synchronization of internally generated audit records with external events might require synchronization with a generally recognized external time source (such as the Global Positioning System (GPS), Global Navigation Satellite System (GLONASS) and Galileo). The time source should be protected from unauthorized alteration.			
12	SR 3.1 - Communication integrity <Description> The control system shall provide the capability to protect the integrity of transmitted information. <Passing Criteria> Show the secure protocol information of transmitted information.	1. Click Start or press the Windows key. 2. In the Start menu, either in the Run box or the Search box, type regedit and press Enter. ... 3. Navigate to follow the registry path: HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols.		
13	SR 3.4 - Software and information integrity <Description>	1. Goto “Windows Settings” menu UI 2. Click “Update and Security”		

	The control system shall provide the capability to detect, record, report and protect against unauthorized changes to software and information at rest. <Passing Criteria> - Integrity check of data at rest (e.g. software, configuration) - Capability to be integrated into a system that can perform or support integrity checks	3. Check “Windows Update” information		
14	SR 4.1 - Information confidentiality <Description> The control system shall provide the capability to protect the confidentiality of information for which explicit read authorization is supported, whether at rest or in transit. <Passing Criteria> Ensure Physical security for Controller memory card and make sure proprietary memory card data not readable from normal card reader.	1. Click Start or press the Windows key. 2. In the Start menu, either in the Run box or the Search box, type regedit and press Enter. ... 3. Navigate to follow the registry path: HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols. 4. The connection uses secure channel.		
15	SR 4.3 - Use of cryptography <Description> If cryptography is required, the control system shall use cryptographic algorithms, key sizes and mechanisms for key establishment and management according to commonly accepted security industry practices and recommendations. <Passing Criteria> - Use of standardized cryptographic protocol - Use of recommended protocols (e.g. BSI TR-02102) - Used according to proven practices or documentation	N/A No cryptography function is used in the host.		
16	SR 6.1 - Audit log accessibility <Description>	1. Goto “Event Viewer” menu UI 2. Expand the “Windows Logs”		

	The control system shall provide the capability for authorized humans and/or tools to access audit logs on a read-only basis. <Passing Criteria> - Capability for authorized humans or tools to access audit logs on a read only basis - Web interface (audit perspective) - Console tools (separate information system for audit access)	3. Check the logs of Application, Security, System,…		
17	SR 7.3 – Control System backup <Description> The identity and location of critical files and the ability to conduct backups of user-level and system-level information (including system state information) shall be supported by the control system without affecting normal plant operations. <Passing Criteria> Host Server is set up so that Up-to-date backups are available for full system recovery in the event of a system failure or misconfiguration. Audit logs and other forensic information should be included in the backups.	1. An Acronis backup tool will be installed in the host during SAT.		

3.5 DATA PROTECTION INSPECTION

Item	Description & Pass Criteria	Inspection/Test Steps	Results (P,N,N/A)	Remarks
1	C22 : Management of Change (MOC) - Well-defined management of Change procedure, independent review, administrative Control, passive Countermeasure			
2	C37 : Backup and restore the System/Software/Data - Build a backup and restore for the System/Software/Data			
3	C15 : Encrypted Communiacations - Assuming robust encryption algorithm to protect sensitive data in transit or at rest (e.g., AES)			

3.6 HARDWARE PROTECTION INSPECTION

Item	Description & Pass Criteria	Inspection/Test Steps	Results (P,N,N/A)	Remarks
1	C6 : Block/disable unused ports - Well-defined hardening process, device owner, periodic review of implemented hardening, active countermeasure			
2	C19 : Locked Enclosure - Well-defined physical security practices with security personnel and periodic inspection, active countermeasure			

3.7 SYSTEM ADMINISTRATION INSPECTION

Item	Description & Pass Criteria	Inspection/Test Steps	Results (P,N,N/A)	Remarks
1	C2 : Access control list of who has access to engineering source file - Well-defined account management process, consistent guidelines for strong passwords, passive countermeasure			
2	C3 : Anti-virus software or End-point Protection - Well-defined hardening process, device owner, periodic anti-virus table updates, automatic scanning, active countermeasure			
3	C6 : Block/disable unused ports - Well-defined hardening process, device owner, periodic review of implemented hardening, active countermeasure			
4	C20 : Log review/analysis - Well-defined cybersecurity incident detection and response procedure, clearly defined roles and responsibilities, clearly defined log review frequency, passive countermeasure			
5	C23 : Multi-Factor Authentication (MFA) - Well-defined account management process, consistent guidelines for strong passwords, active countermeasure			
6	C26 : Periodic review of the Application Program - Well-defined cybersecurity incident detection and response procedure, clearly			

	defined roles and responsibilities, ensure alarm management principles are considered, passive countermeasure			
7	C29 : Remove Unneccessary Services - Well-defined hardening process, device owner, periodic review of implemented hardening, active countermeasure			
8	C30 : Remove Unneccessary Software - Well-defined hardening process, device owner, periodic review of implemented hardening, active countermeasure			
9	C32 : Review of User Accounts and Permissions (former employees, e.g. retired, terminated) - Well-defined account management process, consistent guidelines for strong passwords, passive countermeasure			
10	C34 : SIEM- Security incident and event monitoring - Well-defined cybersecurity incident detection and response procedure, clearly defined roles and responsibilities, tuning and configuration of SIEM, ensure alarm management principles are considered, passive countermeasure management			
11	C34 : SIEM- Security incident and event monitoring - Well-defined cybersecurity incident detection and response procedure, clearly defined roles and responsibilities, tuning and configuration of SIEM, ensure alarm management principles are considered, passive countermeasure management			
12	C35 : Strong Unique Passwords - Well-defined account process, consistent guidelines for strong passwords, passive countermeasure			
13	C37 : Backup and restore the System/Software/Data - Build a backup and restore for the System/Software/Data			
14	SIEM- Security incident and event monitoring – Robustness testing and stress testing for Windows event storms.			

3.8 APPLICATION SECURITY INSPECTION

Item	Description & Pass Criteria	Inspection/Test Steps	Results (P,N,N/A)	Remarks
1	C2 : Access control list of who has access to engineering source file - Well-defined account management process, consistent guidelines for strong passwords, passive countermeasure, and role-based use control matrix.			
2	C32 : Review of User Accounts and Permissions (former employees, e.g. retired, terminated) - Well-defined account management process, consistent guidelines for strong passwords, passive countermeasure			
3	C35 : Strong Unique Passwords - Well-defined account process, consistent guidelines for strong passwords, passive countermeasure			

3.9 NETWORK SECURITY INSPECTION

Item	Description & Pass Criteria	Inspection/Test Steps	Results (P,N,N/A)	Remarks
1	C24 : NIDS- Network intrusion detection system - Well-defined cybersecurity incident detection and response procedure, clearly defined roles and responsibilities, ensure alarm management principles are considered, passive countermeasure			
2	Firewall & Rule Policy	1. Check Firewall rules for restriction of access paths for limiting the allowed asset and service connetion from Working Zone to Supervisory zone. 2. Check Firewall rules for restriction of of access paths for limiting the allowed asset and service connetion from Substation Zone to		

		Supervisory zone and Service zone.		
3	Zone & Conduit Segmentation , including data flow checking, which should compliance with DTRA.	1. It may use IDS tool to collect the packets and analysis the network architecture 2. It may type “netstst” to check the network connect and analysis the network architecture 3. Check the zone segmentation mechanism based on TRA report and data flow diagram.		
4	Traffic robustness test and stress test	1. Evaluate Traffic robustness, including network capability 2. Test Traffic stress 3. Check Traffic Storm protection, including rate-limiting network devices		

3.10 ADVANCED MITIGATION STRATEGIES INSPECTION

Item	Description & Pass Criteria	Inspection/Test Steps	Results (P,N,N/A)	Remarks
1	C1 : 24 Hour Operator staffing - Well-defined cybersecurity incident detection and response procedure, clearly defined roles and responsibilities, ensure alarm management principles are considered, passive countermeasure			
2	C12 : Door Locks - Well-defined physical security practices with security personnel and periodic inspection, active countermeasure			
3	C17 : Firewall logs that monitor access - Well-defined cybersecurity incident detection and response procedure, clearly defined roles and responsibilities, ensure alarm management principles are considered, passive countermeasure			

4	C20 : Log review/analysis - Well-defined cybersecurity incident detection and response procedure, clearly defined roles and responsibilities, clearly defined log review frequency, passive countermeasure			
5	C21 : Managed Switch with Access Control List (ACL) - Well-defined firewall ACL, device owner, periodic review of ACL, active countermeasure			
6	C22 : Management of Change (MOC) - Well-defined management of change procedure, independent review, administrative control, passive countermeasure			
7	C24 : NIDS- Network intrusion detection system - Well-defined cybersecurity incident detection and response procedure, clearly defined roles and responsibilities, ensure alarm management principles are considered, passive countermeasure			
8	C33 : Separation of duty (limiting the number of critical systems that can be impacted from a single account) - Well-defined account management process, consistent guidelines for strong passwords, active countermeasure			

3.11 POLICIES & PROCEDURES INTEGRATION REQUIREMENTS INSPECTION

Item	Description & Pass Criteria	Inspection/Test Steps	Results (P,N,N/A)	Remarks
1	SM-1 : User Account & Access Control Management - Microsoft Windows AD			
1-1	SM-1 : User Account & Access Control Management - Microsoft Windows AD: auto-login and operator accounts, and other accounts required for essential functions and/or continuous operations, or as required by the asset owner have been configured so that they never	TBD		

	expire nor become disabled automatically.			
1-2	SM-1 : User Account & Access Control Management - Microsoft Windows AD: generate audit log that contains the entries for the removed user accounts that are no longer needed			
1-3	SM-1 : User Account & Access Control Management - Microsoft Windows AD: – retrieve the expiry period requirements from the asset owner, – configure password expiry to meet those requirements			
1-4	SM-1 : User Account & Access Control Management - Microsoft Windows AD: – retrieve the number of days for prompting users before password expiry from the asset owner – configure password expiry to meet that requirement			
1-5	SM-1 : User Account & Access Control Management - Microsoft Windows AD: identify and change the default passwords according to the requirements of the asset owner			
1-6	SM-1 : User Account & Access Control Management - Microsoft Windows AD: Ensure that previous *N* passwords are not reused			
1-7	SM-1 : User Account & Access Control Management - Microsoft Windows AD: Ensure that passwords are not changed more than once every N days			
1-8	SM-1 : User Account & Access Control Management - Microsoft Windows AD: Ensure that securely document and maintain the retrieved passwords			

2	SM-2 : Assets Management Sever (AMS) - OPSWAT Neuralyzer			
3	SM-3 : Backup/ Restore Mechanism - A Local Backup Server and/or NAS			
4	SM-4 : Backup/ Restore Mechanism - Acronis Agent & integrated to Data Center			
5	SM-5 : Anti-Malware Protection Mechanism - Palo Alto Antivirus SW, A DMZ Patch Management Server and , an approval portable media (if applicable)			
6	SM-6 : Security monitoring and log collection - SPLUNK local agent and integrated to CENTER SIEM - Function test for the event management solution - Verify effectiveness of safeguarding through documented process and criteria - Check documented process showing that the reporting interface is commonly accepted and current, and not obsolete or unacceptable			
7	SM-6 : Security monitoring and log collection - SPLUNK local agent and integrated to CENTER SIEM - Security event and response exercise, including protection against event stroms			
8	SM-7 : Patch Management - A DMZ Patch Management Server			
9	SM-8 : Network Intrusion Dection (IDS) Mechanism - OPSWAT Neuralyzer			
10	SM-9 : Portable Disk Vulnerability & Malware Management - OPSWAT MetaDefender Kiosk™			

11	SM-10 : Security Policy & Procedure Documents (Function/Operation Documents)			
12	SM-11 : System Security Hardening			

3.12 HARDENING REQUIREMENTS INSPECTION

Item	Description & Pass Criteria	Inspection/Test Steps	Results (P,N,N/A)	Remarks
1	Patch and update the OS			
2	Remove or disable unnecessary services, applications, and network protocols			
3	Configure OS user authentication			
4	Configure access controls appropriately, include mutual authentication for the administration of network devices (if applicable)			
5	Install and configure additional security controls			
6	Test the security of the OS			
7	Removal of unnecessary user accounts			
8	Strong remote access controls (e.g. multifactor authentication)			
9	Recommended to use a tool (e.g. Center for Internet Security (CIS) Security Configuration Benchmarks for Window server) to collect and inspect the configuration settings			

3.13 VULNERABILITY SCAN

Item	Description & Pass Criteria	Inspection/Test Steps	Results (P,N,N/A)	Remarks

1	Comprehensive Network Scan	Nessus : • Network Scanning • Vulnerability Detection • Credentialed Scanning • Plugin-Based Scanning • Compliance Checks • Automated Reporting		
2	Network Analysis	NMAP		
3	Network scan and analysis with Nmap during normal operation	• System startup to normal operation (SIT stage) • Startup nessus scan • Do the Nmap test in the same time		

3.14 INSPECTION/TEST CASE FOR SIS

Item	Description & Pass Criteria	Inspection/Test Steps	Results (P,N,N/A)	Remarks
1	The SIS communications critical to safety functions shall not be affected by other communications of the Automation Solution. It should have the physical separation of BPCS communications and the SIS.	(7.4.1.7.-1)		
2	The external communications to the Automation Solution, including remote access communications, shall not be able to interfere with the operation of the SIS.	(7.4.1.7.-2)		
3	The applications external to the SIS shall not be able to participate in disrupt or otherwise interfere with SIS communications that are critical to safety functions.	(7.4.1.7.-3)		
4	The SIS EWSs that reside outside the SIS should be protected from compromise by communications from Level 3 or above. Access from Level 3 applications to SIS engineering workstations that reside within the SIS is prohibited.	(7.4.1.7.-4)		
5	The SIS engineering workstations within the SIS (1a) either should not	(7.4.1.7.-5)		

	have remote access installed or (1b) should be disabled (not accessible), and/or (2) have security mechanisms that block remote access communications with these workstations.			
6	All access to the Automation Solution's SIS from outside the SIS shall be mediated and authorized at the interface to the SIS. Access controls to the SIS should be implemented at the interface to the SIS.	(7.4.1.7.-6)		
7	The SIS functions performed by the Automation Solution's SIS EWSs shall be protected from compromise by other SIS EWS software. It should reduce the possibility that the SIS EWS will contain T3 offline software (see IEC 61508-3) that could intentionally or inadvertently cause harm to the SIS. It should prohibit the SIS EWS from being configured to perform non-SIS functions.	(7.4.1.7.-7)		
8	Unauthorized wireless devices shall not be used as an integral part of SIS safety functions, to prevent attacks against the SIS by unauthorized wireless devices.	(7.4.1.7.-8)		
9	It shall provide a function process and/or procedure document to enable and disable a hardware implementation of the configuration mode interface required by SP.05.09 BR and to physically lock this hardware implementation while the configuration mode is disabled.	(7.4.1.7.-9. (1))		
10	It shall provide a function process and/or procedure document that can be performed for an independent third-party to verify that it is not possible to change the configuration of the SIS when the hardware interface described in SP.05.09 RE (1) is locked in the "disable" configuration mode.	(7.4.1.7.-9. (2)) 1. Check if the device provide the hardware interface provides switch function to prevent changing the configuration of the IED (SIS)		

		2. Check if this function is tested or gets a certificate from an independent third-party		

3.15 INSPECTION/TEST CASE FOR WIRELESS (IF APPLICABLE)

Item	Description & Pass Criteria	Inspection/Test Steps	Results (P,N,N/A)	Remarks
1	The automation solution architecture documentation describing wireless systems should include its process to document the architecture of its wireless networks and data flows, its implemented security mechanisms to prevent intrusion or bypass of specified access restrictions.	(7.4.1.6.-1)		
2	Ensure that access to wireless devices is protected by authentication and access control mechanisms that are commonly accepted by both the security and industrial automation communities.	(7.4.1.6.-2)		
3	Ensure that wireless communications are protected by cryptographic mechanisms that are commonly accepted by both the security and industrial automation communities.	(7.4.1.6.-3)		
4	Ensure that wireless protocols used in the automation solution are compliant with standards commonly used within the industrial security community and with applicable regulations.	(7.4.1.6.-4)		
5	Ensure that its rules for naming wireless network identifiers provide unique identifiers and prevent an easy identification of the associated site or function.	(7.4.1.6.-5)		
6	Ensure that the automation solution's wireless devices that have IP addresses use static addressing and have dynamic	(7.4.1.6.-6)		

	address assignment mechanisms (e.g. DHCP) disabled			
		1.		

4.0 APPENDIX

4.1 PATCH APPLICATION FORM

Name	Information or Note
Title	
Asset ID	
Date	Date to patch
Type of Patch	Software, firmware
Patch Name /Description	
Patch ID and/or version	
Patch Release Date	
Vulnerability/CVE	If applicable
Affected Asse	List the specific systems, servers, applications, or assets affected
Severity of Vulnerability	Brief description of the risk or vulnerability addressed by this patch, including potential consequences of not applying it
Validation for the Patch	Provide the test result if applicable

Backup Status	Confirm that a complete backup of the system has been made and is available
Rollback Plan	Provide a brief description of the rollback procedure in case of failure
Executor	Company: Name: (Sign)
Approval	[ ] Yes / [ ] No Name: (Sign)
Comments/Concerns	insert any comments or concerns from the asset owner, if any

4.2 CHECKLIST FOR SECURITY HARDENING LEVEL AFTER PATCH INSTALLATION,

The follow table could be used to checklist for Temporary Deactivated Hardening Measures.

No.	Hardening Measure	Status Before Patch	Action Taken During Patch	Status After Patch	Responsible Party	Comments
1	Disable Firewall Rules	Active / Disabled	Disabled / Re-enabled	Active / Disabled		
2	Disable Intrusion Detection System	Active / Disabled	Disabled / Re-enabled	Active / Disabled		
3	Disable Antivirus / Malware Scanners	Active / Disabled	Disabled / Re-enabled	Active / Disabled		
4	Disable Logging Services	Active / Disabled	Disabled / Re-enabled	Active / Disabled		

The follow table could be used to checklist for Temporarily Applied Configuration Changes During Patch Installation.

No.	Configuration Change	Before Patch Installation	Temporary Change During Patch	After Patch Installation	Responsible Party	Comments
1	Port Number Change	[Port Number]	[Port Number]	[Port Number]		
2	Configuration File Change	[Original Value]	[New Value]	Update Value		
3	User Permissions Change	[Original Permission]	[New Permission]	[Original Permission]		
4	Network Interface Change	[Original Setting]	[New Setting]	[Original Setting]		

The follows are as an example of verification / validation step of former hardening level after patch installation.

Verification Step	Action to Perform	Responsible Party	Comments
1. **Verify Firewall Rules**	Check that all necessary firewall rules are active and correctly configured.		
2. **Verify IDS/IPS**	Confirm that the IDS/IPS system is active and properly monitoring for potential threats.		
3. Check Antivirus/Malware Scanners	Ensure that antivirus/malware scanning is operational and updated to the latest signature set		
4. Check System Logs	Ensure logging services (e.g., syslog, auditing) are enabled and logs are being generated.		

<<Text End>>